

GitHub PR 自动合并

生产实践指南

Go 单元测试 + AI 安全审计通过后自动合并到 main

适用架构：GitHub Actions Hosted Runner + Go + Ollama Cloud / GLM-5.2

核心目标

PR 创建后自动执行 Go 单元测试和 AI 安全审计。只有 Required Checks 全部通过，GitHub 才自动完成 Merge；任意检查失败则保持 PR 未合并。

版本：1.0 | 生产基线设计

1. 目标架构

自动合并不应该由某个脚本自行判断“测试是否通过”，而应把 GitHub Branch Rules / Ruleset 作为最终的硬门禁。auto-merge Workflow 只负责为 PR 开启 GitHub 原生 Auto-merge。

最终数据流



关键原则

test.yml 和 audit.yml 负责产生可验证的 GitHub Checks；Ruleset 决定是否允许合并；auto-merge.yml 只登记“条件满足后自动合并”的意图。不要绕过 Ruleset 直接执行管理员合并。

2. 前置条件

1. 仓库已有 test.yml，并能在 PR -> main 时产生稳定的 Go Unit Tests Check。
2. 仓库已有 audit.yml，并能在 PR -> main 时产生稳定的 AI Security Audit Check。
3. 安全审计必须具备失败门槛，例如 AUDIT_FAIL_ON=high；如果仍为 none，则“安全审计通过”没有真正的阻断意义。
4. Repository Settings -> General -> Pull Requests 中启用 Allow auto-merge。
5. main 分支配置 Ruleset：Require a pull request before merging + Require status checks to pass before merging。
6. 把 Go Unit Tests 与 AI Security Audit 配置为 Required status checks。

注意：Required Check 名称

Ruleset 中选择的是 GitHub 实际产生的 Check 名称，通常对应 jobs.<job-id>.name。修改 Job name 后，要同步检查 Ruleset 中的 Required Check。

3. 单元测试与安全审计 Gate

建议 test.yml 在 PR 阶段与 main push 阶段运行；audit.yml 至少在 PR 阶段运行。自动合并只依赖 PR 最新 HEAD SHA 上的 Required Checks。

test.yml 中的 Required Check 示例

```
jobs:
  unit-test:
    name: Go Unit Tests
    runs-on: ubuntu-latest

    steps:
      - uses: actions/checkout@v7

      - uses: actions/setup-go@v7
        with:
          go-version-file: go.mod
          cache: true

      - run: go mod download
      - run: go test -v -count=1 ./...
```

audit.yml 中的 Required Check 示例

```
env:
  AUDIT_FAIL_ON: high

jobs:
  audit:
    name: AI Security Audit
    runs-on: ubuntu-latest

    steps:
      # go vet / govulncheck / gosec / GLM-5.2 audit
      # HIGH 或 CRITICAL 命中时 audit.sh 应返回非 0
      - run: bash .ai/skills/go-security-audit/scripts/audit.sh
```

推荐门槛：第一阶段若准备自动合并，至少使用 high：CRITICAL/HIGH 阻止 Merge，MEDIUM/LOW 仅报告。

4. GitHub Repository 配置

4.1 开启 Auto-merge

```
Repository
-> Settings
-> General
-> Pull Requests
-> Allow auto-merge [ON]
```

GitHub 原生 Auto-merge 会等待所有合并要求满足，例如 Required Reviews 和 Required Status Checks，通过后才真正合并。

4.2 main Ruleset

```
Repository
-> Settings
-> Rules
-> Rulesets
-> New branch ruleset
-> Target: main

Enable:
[x] Require a pull request before merging
[x] Require status checks to pass before merging

Required checks:
[x] Go Unit Tests
[x] AI Security Audit
```

生产建议

不要给普通用户、机器人或 GitHub Actions 配置宽泛的 Ruleset bypass。应让 Required Checks 成为任何自动合并之前都无法绕过的硬条件。

5. auto-merge.yml 完整配置

创建文件：.github/workflows/auto-merge.yml

```
name: Enable Auto Merge

on:
  pull_request:
    branches:
      - main
    types:
      - opened
      - reopened
      - synchronize
      - ready_for_review

permissions:
  contents: write
  pull-requests: write

concurrency:
  group: auto-merge-${{ github.event.pull_request.number }}
  cancel-in-progress: true

jobs:
  enable-auto-merge:
    name: Enable Auto Merge
    runs-on: ubuntu-latest
    timeout-minutes: 5

    # Draft PR 不自动合并；第一版仅允许同仓库分支。
    if: >-
      ${{
        !github.event.pull_request.draft &&
        github.event.pull_request.head.repo.full_name == github.repository
      }}

    steps:
      - name: Enable GitHub auto-merge
        env:
          GH_TOKEN: ${{ github.token }}
          PR_URL: ${{ github.event.pull_request.html_url }}
          HEAD_SHA: ${{ github.event.pull_request.head.sha }}
        run: |
          set -euo pipefail

          echo "PR: ${PR_URL}"
          echo "Head SHA: ${HEAD_SHA}"

          gh pr merge \
            "${PR_URL}" \
            --auto \
            --squash \
            --match-head-commit "${HEAD_SHA}"
```

5.1 为什么使用 --auto

`gh pr merge --auto` 不是立即强制合并，而是启用 GitHub Auto-merge：只有仓库的合并要求满足后，GitHub 才执行真正的 Merge。因此它天然适合与 Required Checks 配合。

5.2 为什么使用 --match-head-commit

它把当前操作绑定到 PR 最新 HEAD SHA，避免 Workflow 启动后 PR 又新增 commit 时，仍以旧状态继续执行自动合并逻辑。新的 commit 会触发 synchronize，并重新开启针对最新 SHA 的 auto-merge。

5.3 为什么使用 --squash

Squash Merge 可将 feature 分支多个开发 commit 合并为一个主干 commit，通常更适合服务型 Go 项目的 main 历史。若团队希望保留所有 commit，可改为 --merge；希望线性历史可改为 --rebase。

6. 事件与状态流

事件	test.yml	audit.yml	auto-merge.yml
PR opened	Run	Run	Enable auto-merge
PR synchronize	Re-run latest SHA	Re-run latest SHA	Re-bind latest SHA
Draft PR	可运行	可运行	Skip
ready_for_review	按 test.yml 配置	按 audit.yml 配置	Enable auto-merge
Unit Test FAIL	Failure	-	GitHub 不合并
Security Audit FAIL	-	Failure	GitHub 不合并
两者 PASS	Success	Success	GitHub 自动 Merge

失败修复后的状态变化

```
Commit A
|-- Unit Test PASS
|-- Security Audit FAIL
|-- PR remains open

Developer fixes vulnerability -> Commit B
|-- pull_request:synchronize
    |-- old runs cancelled (if concurrency enabled)
    |-- Unit Test reruns
    |-- Security Audit reruns
    |-- auto-merge binds to Commit B

Commit B
|-- Unit Test PASS
|-- Security Audit PASS
|-- GitHub automatically merges to main
```

7. 权限与安全边界

- test.yml 与 audit.yml 建议维持 contents: read；只有 auto-merge.yml 获得合并所需的写权限。
- auto-merge.yml 不使用 --admin，避免绕过 Required Checks / Ruleset。
- 第一版仅允许同仓库分支自动合并，避免 fork PR 直接进入付费审计和自动合并链路。
- 不要把 OLLAMA_API_KEY 放到 auto-merge.yml；它只属于 audit.yml。
- GitHub Actions 的 job 如果被 skipped，GitHub 可能把该 Check 视为成功，因此 Required Audit Job 的 if 条件必须慎重设计。
- 如果 Organization policy 阻止 GITHUB_TOKEN 执行合并，优先使用最小权限 GitHub App Token，而不是 Personal Access Token 长期驻留。

重要：不要让 Required Audit 被“跳过即成功”绕过

如果 AI Security Audit 被配置为 Required Check，就不要因为普通条件判断在目标 PR 上直接 skip 整个 job。若确实需要区分 fork PR，应为 fork 设计独立安全策略，而不是依赖 skipped 作为安全通过。

8. Required Checks 的严格度选择

模式	含义	建议
Strict	PR 分支必须基于最新 main，Required Checks 才可合并。	多人并发修改同一服务时更安全，但可能增加重复 CI。
Loose	只要求 PR 自身 Required Checks 成功，不强制与最新 main 同步。	CI 更少，但存在合并后集成冲突风险。

生产建议：核心后端服务优先考虑 Strict；如果 CI 成本较高且团队提交频率很高，可结合 Merge Queue 再优化。

9. Merge 后的 main 验证

自动合并成功后，建议 test.yml 继续监听 main push，再对主干最终状态执行一次 Go 单元测试。

```
on:
  pull_request:
    branches: [main]

  push:
    branches: [main]
```

AI Audit 是否在 main push 后再执行，可根据成本与风险决定。若开启 Post-Merge Audit，应比较 github.event.before...github.sha，只审本次进入 main 的增量，避免重复审整个仓库。

10. 推荐上线步骤

1. 先确保 test.yml 在 PR 最新 SHA 上稳定运行并能正确失败。
2. 将 audit.yml 的 AUDIT_FAIL_ON 从 none 调整为 high，并验证 HIGH/CRITICAL 能使 Job 非 0 退出。
3. 打开 Repository -> Allow auto-merge。
4. 创建 main Ruleset，要求 Pull Request，并把 Go Unit Tests、AI Security Audit 设置为 Required Checks。
5. 提交 auto-merge.yml。
6. 用一个测试 feature 分支创建 PR：先故意让单测失败，确认不会 Merge。
7. 修复单测，再制造一个 HIGH 级安全问题，确认 Audit Failed 时不会 Merge。
8. 修复安全问题并 push 新 commit，确认 synchronize 重新执行 CI，两个 Required Checks PASS 后自动 Squash Merge。
9. 确认 Merge 后 main 的 test.yml 再次运行。
10. 稳定运行后再评估是否增加 Review 审批、Merge Queue、Post-Merge Audit 或 GitHub App Token。

11. 常见问题排查

现象	检查项
两个 CI 都 PASS，但没有自动 Merge	确认仓库已启用 Allow auto-merge；检查 auto-merge job 是否执行成功；检查 PR 是否 Draft、是否存在 Required Review、冲突或 Ruleset 其他条件。
gh pr merge 返回权限错误	检查 workflow permissions、Organization policy、contents/pull-requests write；必要时使用 GitHub App Token。
Ruleset 中找不到 Check 名称	先让 Workflow 至少运行一次，再在 Ruleset 添加实际出现的 Check；确认 jobs.<id>.name 未改名。
Audit 被 Skip 但 PR 仍可合并	Skipped Check 可能被视为 Success。不要把安全必检 Job 用普通 if 直接跳过；重新设计触发和 fork 策略。
PR 新 commit 后错误自动合并	确认使用 --match-head-commit，并监听 synchronize。
Auto-merge 一直等待	检查 Required Checks、Required Review、branch up-to-date、merge conflict、ruleset bypass/限制及 merge queue 设置。

12. 生产上线检查清单

- | | |
|---|---|
| ☐ main 已启用 Require a pull request before merging | ☐ Go Unit Tests 已配置为 Required Check |
| ☐ AI Security Audit 已配置为 Required Check | ☐ AUDIT_FAIL_ON 已设置为 high 或更严格，而不是 none |
| ☐ Repository 已开启 Allow auto-merge | ☐ auto-merge.yml 不包含 --admin |
| ☐ auto-merge.yml 使用 --match-head-commit | ☐ Draft PR 不自动合并 |
| ☐ Fork PR 自动合并策略已经明确 | ☐ test/audit Job 名称与 Ruleset 中 Required Check 一致 |
| ☐ Ollama API Key 仅保存在 GitHub Secrets 中 | ☐ main Merge 后仍有基础验证测试 |

13. 官方参考

- GitHub Docs - Automatically merging a pull request (docs.github.com)
- GitHub Docs - Managing auto-merge for pull requests in your repository (docs.github.com)
- GitHub Docs - Available rules for rulesets / Required status checks (docs.github.com)
- GitHub Docs - Status checks (docs.github.com)
- GitHub CLI Manual - gh pr merge: --auto / --match-head-commit / --squash (cli.github.com)
- GitHub Actions - actions/checkout and actions/setup-go official repositories (github.com/actions)

建议把本指南与 .github/workflows/test.yml、audit.yml、auto-merge.yml 一起纳入仓库版本管理，并在 CI 策略变更时同步更新。